KAYAN TRUSTGATE

Governed Autonomous Pentesting

Project proposal and implementation report



Actual 3D operations console; screenshot cropped for the cover.

SUBMITTED BY

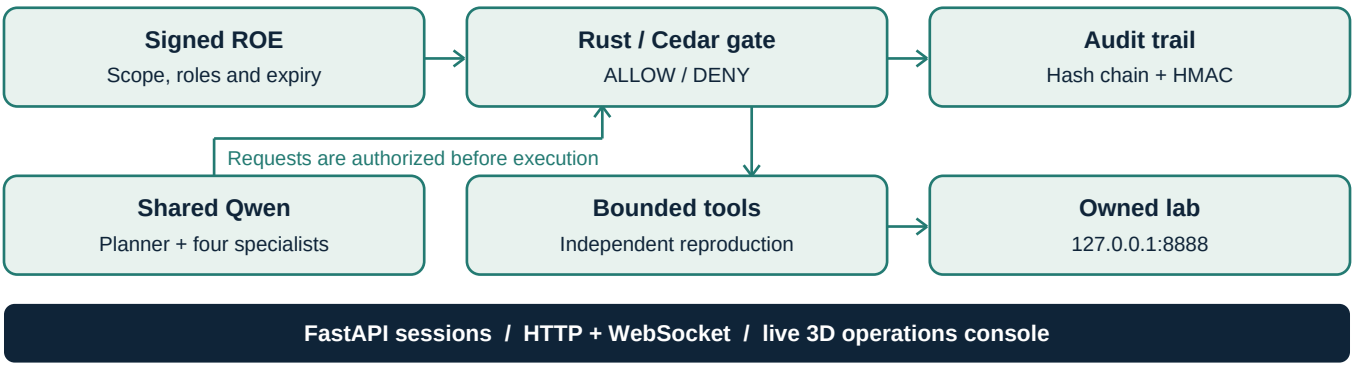
Student name	Student ID	Program
Khaled Mohamed	20231160	Cybersecurity
Youssef Montasser	20236209	Cybersecurity
Ahmed Ali Moustafa Badawi	20230524	Cybersecurity
Mahmoud Ahmed Fathy Ashry	20230249	Cybersecurity
Talal Yousif Norelhuda Elhag	20236211	Cybersecurity

PROJECT FOCUS

Signed Rules of Engagement, deterministic policy enforcement, inspectable agent sessions and evidence-based reporting.

Six TA sections are followed by a deliverables coverage matrix. Evaluation results, methodology substitutions and open limitations are stated explicitly.

1. System Overview & Architecture



KAYAN is a TrustGate-governed autonomous penetration-testing platform. Recon, Web-App and Network constitute its Red Team: they propose and perform bounded offensive tests against the local authorized lab. Reporting constitutes its Blue Team, assembling the evidence-based report and defensive recommendations. Planner coordinates these roles without becoming another offensive or defensive specialist. This allocation reuses the existing agents; it does not create additional execution authority.

The authorization foundation is a signed Rules of Engagement (ROE) contract. A Rust/Axum service authenticates the contract and uses Cedar policies to evaluate requested actions against enrolled roles, targets, techniques and time limits. The Python execution engine submits model and tool requests through this gate. Its executor exposes a fixed catalogue of lab operations rather than arbitrary model-selected shell commands or URLs. Supported candidate findings require a fresh second request before publication. Decisions are recorded in a hash-chained, HMAC-signed audit file; the storage remains mutable and must not be described as immutable.

The local Qwen2.5:7b model is shared across Planner, Recon, Web-App, Network and Reporting, with role-specific prompts and capability contracts. In the TA's base/helper/worker terminology, Qwen is the common inference base and the agents are specialized software workers around it. A shared model was chosen to fit the local compute and project-time budget; a distinct helper model was not implemented or evaluated. This is a design substitution, with no measured claim about a second model's capability, cost or latency. Calls are serialized within the configured local context and output budgets. A/B/C capability labels regulate context verbosity and responsibilities, rather than representing three independently trained models.

A FastAPI backend persists agent sessions and broadcasts snapshots over a WebSocket. A React Three Fiber/Three.js office presents the five workstations, current tasks, role tiers, transcripts and governance decisions. The backend and 3D client communicate through HTTP and WebSocket interfaces. The Python engine is the primary demonstration path. A separate upstream Go PentAGI integration provides a scoped enforcement comparison, with delegation limitations disclosed below. No equivalent sandbox guarantee is established for the Python process.

2. Required Data Inputs

The implemented optional descriptive inputs are company size (company_size), departments (departments), infrastructure summary (infrastructure_summary), network architecture (network_architecture), data storage (data_storage) and customer touchpoints (customer_touchpoints). **These six fields carry zero policy weight.** They frame Reporting's narrative and may separately be analyzed by the offline Risk Plan. They are treated as untrusted descriptions, not verified organizational facts, operator instructions or permission to test. Empty descriptive context is supported; unknown fields, invalid types and excessive lengths are rejected.

Authorization inputs are a separate tier. The signed ROE specifies targets, authorized techniques, forbidden actions and the permitted time window, alongside the role/action contract used by the gate. Descriptive context is held outside the ROE and does not enter signing, loading or Cedar authorization inputs. Keeping these tiers separate prevents a statement such as an infrastructure description from silently expanding the testing scope. Reporting's model-written narrative remains unvalidated narrative even when its input has passed structural validation.

3. Core Deliverables & Logic Flow

Phase 1, the Risk Plan, is a standalone offline retrieval operation. TF-IDF retrieval over the pinned MITRE ATT&CK/OWASP index produces up to three hypothetical risks, ranked by textual relevance and accompanied by references and explicit uncertainty. Ranking is not a measured severity, probability or business-loss estimate. Insufficient context or no matching references produces an explicit empty outcome. This path accesses no target, calls no model or tool, and performs no TrustGate authorization.

Phase 2 offers two evidence paths. Option A, Direct Mitigation, passes Phase 1's hypotheses into the existing Reporting agent's deterministic structured builder. Shared defensive templates and retrieved references produce recommendations without another model inference or live assessment. The result explicitly contains zero verified findings and a hypothetical evidence basis. It is the lower-execution-effort path, not an experimentally measured saving in analyst time.

Option B, Pentest-to-Mitigation, uses the existing live governed assessment. Supported reproduced findings and their runtime proof/audit references feed the same mitigation structure. A saved completed report can be displayed without starting another assessment. The reporting layer checks the proof envelope supplied by the runtime; displaying the report does not independently reproduce the finding or cryptographically verify the entire execution history.

The recorded synthetic planning fixture produced three hypothetical risks, three Option A recommendations and zero findings. The separate Option B view of saved engagement 7da73508-01e6-48e9-9093-be09c5fd734d produced two recommendations from two verified findings. These are different evidence bases, not a quality comparison between the paths. That recorded real-model rehearsal had two findings, 29 allowed decisions and one denied decision, including its deliberately tainted-input probe. The final three-path demonstration reused this saved report rather than launching a fresh live engagement. The source results are preserved in the TA alignment record and recorded functionality checkpoint.

4. Blue Team Configuration & Pricing Logic

Reporting recommendations expose Defense in Depth and Zero Trust grouping filters, inclusion controls and additive illustrative point weights. A filter changes the visible grouping without changing inclusion. Excluding a recommendation changes the displayed total; export preserves the original recommendation evidence and records the presentation selection separately. These controls implement the mapped requirement for configurable strategic-framework presentation and cost-responsive output through a transparent relative-weight mechanism.

The exact shipped disclaimer is: **“Illustrative relative effort/cost only. Points are comparison weights, not prices, quotes or measured implementation effort.”** There is no real pricing or billing engine. The project has no measured implementation-cost dataset or calibrated commercial estimator; presenting the weights as prices would therefore create unsupported precision. This is an explicit bounded interpretation of the mapped requirement, not a claim that actual procurement pricing or mitigation effectiveness has been validated. Selecting a framework or a recommendation does not change authorization or agent execution.

5. LLM Training & Framework Evaluation Task

Fine-tuning was considered and rejected at the design stage because of local infrastructure and project-time constraints. No training experiment was conducted. The implemented substitution is a pretrained local Qwen2.5:7b model with role prompts, skill packets and retrieved ATT&CK/OWASP context; these additions do not change trained weights. The combined local index already contains both MITRE ATT&CK and OWASP Top 10. A query may retrieve either framework, so using the combined index does not imply that every model call receives both.

The recorded grounding-off/on engagements address whether this substitution improved bounded worker outcomes. In original v1, grounding off produced one finding, 23 allowed decisions, one denied decision and 20% findings-based MITRE coverage. Grounding on produced zero findings, 23 allowed decisions, two denied decisions and 0% coverage. The grounded Web-App agent proposed a retrieved skill identifier as a callable tool; the gate denied it and that specialist stopped. This is a preserved action-selection regression, not evidence of improved reasoning.

The later bounded-retry/reference-framing v2 comparison produced the same outcome in both conditions: two findings, 29 allowed decisions, one denied decision and 40% coverage. Both findings reproduced with independent fresh nonces, giving 2/2 reproduction. The unchanged legacy evidence rubric scored 1/2 (50%), because its command-injection criterion recognizes `whoami` output rather than the benign nonce-echo proof. Reproduction and legacy evidence scoring are separate metrics; neither is blinded classification accuracy. Coverage uses five existing lab categories, not the full ATT&CK knowledge base. The XSS evidence is raw script reflection, not confirmed browser execution.

RECORDED EVALUATION RESULT

No grounding improvement was demonstrated. Preserve this failure.

The original regression and later equal outcomes remain in the v1 comparison and v2 comparison. One pair per condition does not establish a hallucination-rate improvement, and the intervening loop changes prevent a causal comparison of v1 and v2 totals. No training duration, trained-framework winner, mitigation-effectiveness score or reduced training-cost figure is available.

The separate scoped Go evaluation recorded three reproduced findings, 19 allowed decisions and 15 denied decisions when its three verifier authorizations are included; Go-only execution had 16 allowed and 15 denied. Its coverage was 40%, fresh reproduction 3/3, and the legacy rubric 1/3. All three flows waited after worker errors and were stopped. Different command menus, model-call gating and workflow decomposition prevent treating these totals as a controlled Python-versus-Go superiority result. This comparison establishes a bounded integration/enforcement result, not a complete replacement runtime or a winner between trained approaches.

6. Pending Tasks / Future Iterations

Blue Team task allocation is resolved: Reporting owns defensive and mitigation synthesis, receiving hypotheses in Option A and reproduced findings in Option B. The remaining work concerns the limitations below rather than an undecided Blue Team role.

Upstream PentAGI/Go worker delegation failures remain documented and unresolved; they are scoped out of the current demonstration. Completion-triggered ROE revocation is not implemented: time-window expiry is enforced, but an engagement finishing does not itself revoke its contract. FBX asset fidelity/re-export and bundle-size cleanup remain explicitly deferred under the user's scope freeze. Existing model-asset loader and bundle warnings must not be represented as fixed by visual polish.

The original acceptance screenshots established functional task/result display but did not measure its roughly two-second task-start criterion. The pre-meeting pass supplied new rendered-frame evidence: one real deterministic fixture showed the current task, working state, tier and new transcript entry within 0.916 seconds of publication. This is a sampled local observation, not a universal latency guarantee; result rendering and expansion were checked separately. The twelve-step closure review preserves the original gap, and the meeting-readiness record documents its bounded recheck. No original checklist item is currently left unobserved within those stated limits; this does not turn sampled visual acceptance into certification of every device or camera angle.

Further production work would require stronger operator identity, demonstrated runtime isolation and audit-storage protections beyond the current mutable local file. The existing tests and owned-lab results do not establish universal semantic taint tracking, validated model narrative, real organizational-risk accuracy or effective deployed mitigations. These boundaries are part of the delivered methodology: the platform demonstrates governed execution and inspectable evidence while retaining negative findings and unfinished requirements openly.

TA Deliverables - Coverage Summary

This crosswalk records how the requested deliverables map to the current implementation. Substitutions are explicit and are not represented as completed training or a second model.

TA requirement	Current delivery	Status
Red / Blue Team structure	Recon, Web-App, Network = Red; Reporting = Blue; Planner coordinates.	Implemented
Base and distinct helper model	One shared Qwen model with role-specific contracts; no separate helper model.	Design substitution
Six organization/context inputs	Six optional descriptive fields; zero policy weight. Signed scope remains separate.	Implemented
Phase 1 Risk Plan	Offline TF-IDF hypotheses, up to three risks, uncertainty and references.	Implemented
Option A - direct mitigation	Reporting consumes hypotheses; no target testing, zero verified findings.	Implemented
Option B - pentest to mitigation	Governed live testing, independently reproduced findings, shared mitigation shape.	Implemented
Strategic frameworks / dynamic cost	Defense in Depth / Zero Trust filters; additive illustrative points and selection export.	Bounded implementation
LLM training-time comparison	No fine-tuning experiment. Pretrained-model retrieval grounding evaluated off/on. No time figure or winner invented.	Methodology substitution
Combined ATT&CK + OWASP approach	Both are included in the pinned local retrieval index. No demonstrated grounding gain.	Implemented; negative/equal outcome
Blue Team task allocation	Reporting owns mitigation synthesis in both Phase 2 paths.	Resolved

EVIDENCE BOUNDARY

Original v1 grounding regressed; v2 off/on outcomes were equal. Reproduction, legacy evidence precision and five-label lab coverage are separate metrics. No classification-accuracy or mitigation-effectiveness claim is made.

Evidence guide

Canonical project documents: TA_PROPOSAL_REPORT.md; TA_DELIVERABLES_ALIGNMENT.md; CLOSURE_EVIDENCE_REVIEW_2026-11-01.md; TA_MEETING_READINESS_2026-11-01.md. Recorded experiments: live_grounding_comparison.md; live_grounding_comparison_v2_bounded_retry.md; pentagi_go_comparison_2026-11-01.md. These are dated evidence records, not newly rerun comparisons.